SecureLogin

SKT ALEPH · 모의해킹 결과 보고서

# 같은 공격 ,
# 두 겹의 방어

웹 · 네트워크 2 중 방어 로그인 시스템 — 무차별 대입 공격 대응


웹 층
**권빈**

네트워크 층
**전지은**


작성일
**2026-11-04**

환경
**격리 VM (VMware)**

# 목차


01 프로젝트 개요

02 팀 구성 및 역할

03 보안 인프라 구성

04 사용 도구

05 사용한 기술과 개념

06 보안 진단 항목 (OWASP)

07 취약점 분석

08 공격 시나리오

09 침투 테스트 ( 방어 OFF)

10 핵심 결과 — 방어 전 / 후

11 침투 탐지 (Suricata)

12 대응 방안

13 결론 및 성과

# 1 프로젝트 개요

반복 로그인 ( 무차별 대입 ) 공격을 웹과 네트워크 두 층에서 막고 , 같은 조건에서 방어 전 / 후를 비교해 효과를 데이터로 증명합니다 .

### 배경

로그인은 모든 서비스의 첫 관문 . 실패 제한이 없으면 공격자가 비밀번호를 무한히 추측할 수 있어 무차별 대입에 노출됩니다 .

### 목표

직접 만든 로그인 사이트에 공격을 재현하고 , 웹 ( 차단 ) 과 네트워크 ( 탐지 ) 두 층의 방어 효과를 전 / 후 비교로 증명합니다 .

### 범위 · 기간

로그인 인증 모듈 · 무차별 대입 1 종에 집중 . 격리 VM 환경 , 2026.10~11.06, 2 인 팀 .

**핵심 차별점 .** 공격 재현에 그치지 않고 , 같은 조건에서 방어 전 / 후가 어떻게 달라지는지를 로그 · 대시보드라는 재현 가능한 증거로 보여 줍니다 .

# 2 팀 구성 및 역할

공통 과업 ( 공격 시나리오 · 방어 전 / 후 비교 · 보고서 ) 은 함께 수행하고 , 아래는 최종 책임 영역입니다 .

**권빈 · 웹 층**

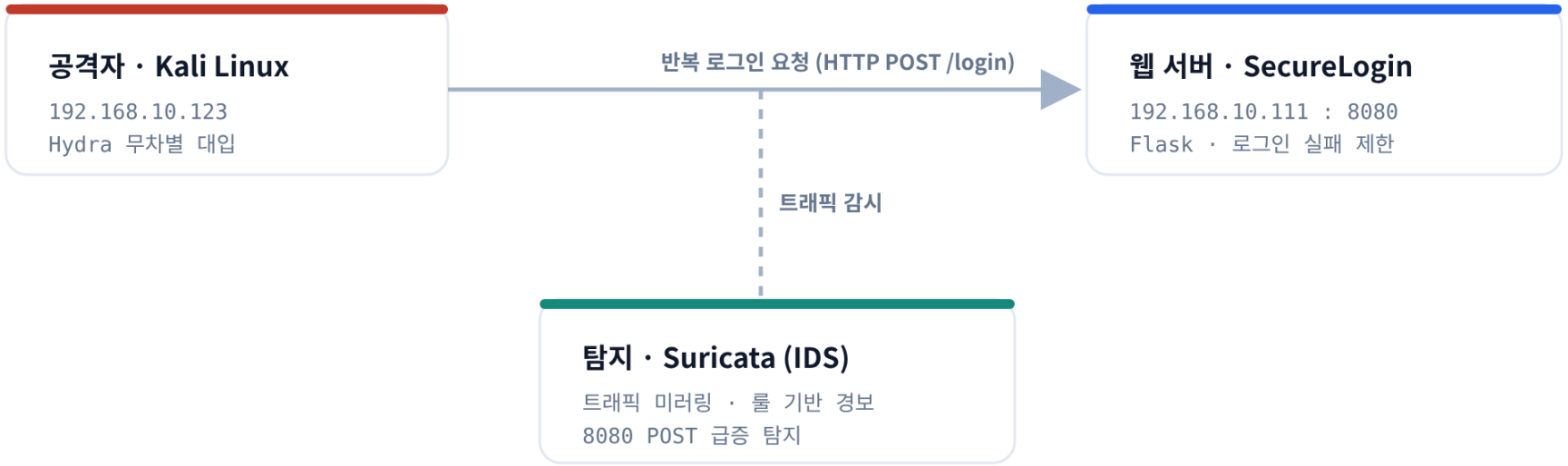
- 로그인 사이트 설계 · 구현 (Flask·SQLite, 해시 저장 )
- 로그인 실패 제한 — 계정 잠금 ·IP 차단
- 이벤트 기록 · 관리자 대시보드 ( 전 / 후 자동 비교 )
- 설치 · 운영 및 결과 검증 ( 원인 분석 · 집계 오류 수정 )

**전지은 · 네트워크 층**

- 공격 환경 구축 (Kali 준비 · 망 통신 연결 )
- 모의 공격 — Hydra 무차별 대입 수행
- 네트워크 탐지 — Suricata 설치 · 룰 작성 · 탐지
- 결과 정리 — 증거 확보 및 결과 문서 작성

# 3 보안 인프라 구성

공격자 (Kali) 가 웹 서버로 반복 로그인을 보내고 , 그 트래픽을 Suricata 가 탐지합니다 . 모든 장비는 격리된 VMware 망에 있습니다 .




**네트워크 층** Suricata 가 공격 패턴을 탐지해 경보 · **웹 층** 실패 임계 초과 시 계정 잠금 · IP 차단

# 4 사용 도구

| 도구 | 역할 | 용도 |
| --- | --- | --- |
| Hydra | 공격 | 로그인 무차별 대입 ( 사전 공격 ) 자동화 |
| Kali Linux | 공격 | 공격자 VM · 보안 도구 모음 |
| Suricata | 탐지 | 네트워크 침입 탐지 (IDS) · 룰 기반 경보 |
| Flask · SQLite | 웹 | 로그인 사이트 구축 · 계정 / 이벤트 저장 |
| werkzeug | 웹 | 비밀번호 해시 저장 · 검증 |
| VMware | 환경 | 격리된 가상 망 ( 외부 · 내부 분리 ) |

# 5 사용한 기술과 개념

처음 보는 사람도 이해할 수 있도록 , 이 프로젝트에서 쓴 핵심 개념을 쉽게 정리했습니다 .

| 용어 | 쉬운 설명 | 이 프로젝트에서 |
|---|---|---|
| 무차별 대입 공격 | 비밀번호를 하나씩 바꿔 넣어 맞을 때까지 시도 | victim 비밀번호를 사전으로 반복 추측 |
| Hydra | 로그인 무차별 대입을 자동 수행하는 공격 도구 | 여러 비밀번호를 빠르게 자동 시도 |
| 로그인 실패 제한 | 실패가 일정 횟수 넘으면 잠시 로그인 차단 | 5 회 실패 시 계정 5 분 잠금 |
| IDS · Suricata | 공격 패턴을 감지해 경보하는 장치 | 몰린 로그인 요청을 탐지해 경보 |
| 비밀번호 해시 | 되돌릴 수 없는 형태로 바꿔 저장 | 원문 대신 해시만 저장 |
| 심층 방어 | 한 겹 뚫려도 다음 겹이 막는 다층 방어 | 네트워크 탐지 + 웹 차단 2 중 |

# 6 보안 진단 항목 (OWASP Top 10)

로그인 기능에서 발생 가능한 취약점과 본 프로젝트에서 다룬 항목을 매핑했습니다 .

| OWASP 항목 | 로그인 기능에서의 문제 | 본 과제 |
|---|---|---|
| A07 인증 실패 | 로그인 실패 횟수 제한 부재 → 무차별 대입 가능 | ★ 집중 |
| A09 로깅 · 경고 실패 | 공격을 기록 · 탐지하지 못하면 대응 불가 | ★ 집중 |
| A02 암호화 실패 | 비밀번호 평문 저장 시 DB 유출로 전 계정 노출 | 일부 |

**A07( 인증 실패 )** 로 생기는 무차별 대입을 공격 · 방어의 중심 주제로 삼고 , **A09( 로깅 · 경고 )** 를 이벤트 기록과 Suricata 탐지로 보완했습니다 . 비밀번호는 해시로 저장해 A02 에도 대비했습니다 .

# 7 취약점 분석 — 무차별 대입 공격

가능한 아이디 · 비밀번호 조합을 자동화 도구로 반복 입력해 유효한 자격증명을 찾는 공격 . 흔한 비밀번호 목록을 쓰는 방식을 사전 공격이라 합니다 .

### 발생 원리 (Mechanism)

- 실패 횟수 제한 부재 → 무제한 시도
- Hydra 로 자동 · 고속 요청
- 응답 문구 · 길이로 성공 / 실패 판별
- 약한 비밀번호는 사전 상위 → 빠르게 뚫림

### 주요 영향 (Impact)

- 계정 탈취 — 유효 자격증명 획득
- 개인 · 민감 정보 열람
- 탈취 계정을 발판으로 2 차 공격

### 핵심 조건

- 로그인 실패를 세고 제한하는 방어가 없을 때
- 흔한 비밀번호를 그대로 허용할 때

# 8 공격 시나리오

공격자가 로그인 폼을 상대로 무차별 대입을 수행하는 전체 흐름입니다 .

| | | |
|---|---|---|
| 1 | **대상 식별** | 로그인 폼 (/login), 입력 필드 (username/password), 실패 문구 확인 |
| 2 | **사전 준비** | 흔한 비밀번호 목록 (pass.txt) 구성 — 정답 iloveyou 포함 |
| 3 | **자동 공격** | Hydra 로 아이디 고정 , 비밀번호를 하나씩 바꿔 반복 요청 |
| 4 | **성공 판별** | 응답에서 성공 표식 (" 환영합니다 ") 탐지 → 유효 자격증명 확보 |
| 5 | **계정 탈취** | 확보한 자격증명으로 로그인 → 정보 접근 |

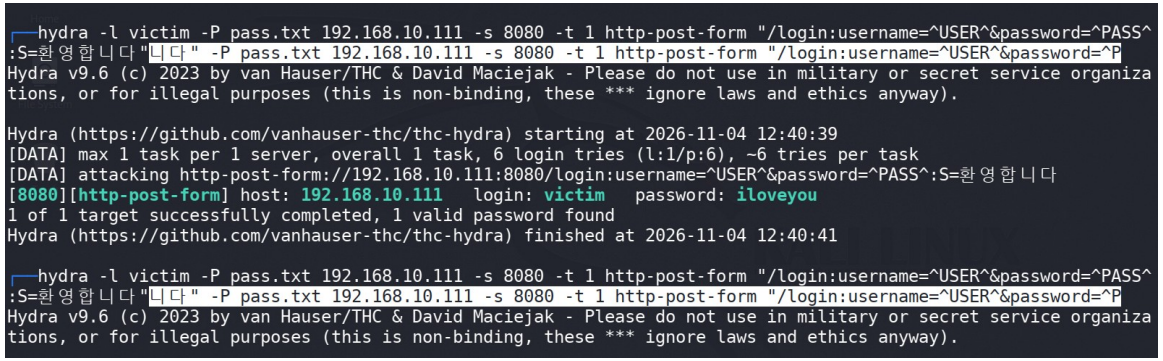
# 9 침투 테스트 ( 방어 OFF)

방어를 끈 상태에서 Hydra 로 victim 계정에 사전 공격을 수행했습니다 .

### 사용 명령

```
hydra -l victim -P pass.txt 192.168.10.111
 -s 8080 -t 1 http-post-form
 "/login:username=^USER^&password=^PASS^:S= 환영합니다 "
```

- -l victim 아이디 고정 · -P pass.txt 사전 · -t 1 순차 요청
- S= 환영합니다 : 이 문구가 보이면 로그인 성공으로 판정




공격자 (Kali) — Hydra 무차별 대입 · victim / iloveyou 획득

### 결과

5 회 실패 후 6 번째 시도 (iloveyou) 에서 로그인 성공 . Hydra 가 **1 valid password found** 로 자격증명을 확보했습니다 .

# 10 핵심 결과 — 방어 전 / 후 비교

SECURELOGIN · 관리자 대시보드

## 방어 전 / 후 비교

동일 공격 `hydra -t 1` · 같은 비밀번호 사전 · victim 계정
방어만 OFF → ON 으로 바꿔 각 1회 수행

| 라운드 | 적용 방어 | 시도 | 성공 | 실패 | 거부 (잠금·차단) | 거부율 | 방어 작동 | 공격 IP | 지속 (초) | 초당 시도 | 결과 (뚫린 계정) |
|---|---|---|---|---|---|---|---|---|---|---|---|
| **1차** 방어 전 · 12:40:39~41 | OFF 없음 | 6 | 1 | 5 | 0 | 0% | 0 | 1 | 1.5 | 3.9 | victim 뚫림 |
| **2차** 방어 후 · 12:41:03~04 | ON 계정 잠금 5회 실패 → 5분 | 6 | 0 | 5 | 1 | 17% | 1 | 1 | 1.4 | 4.3 | 없음 |

단위 — 시도·성공·실패·거부: 로그인 **요청 수** · 방어 작동·결과: **계정** 단위 | 출처 — SecureLogin 서버 이벤트 로그(DB·CSV) 집계

방어를 켜자 로그인 성공 1 → 0, 뚫린 계정 victim → **없음**.

SecureLogin · 2026-11-04

**같은 공격, 다른 결과.** 방어 OFF 는 iloveyou 로 로그인 성공 (victim 뚫림), 방어 ON 은 5 회 실패 후 계정이 잠겨 **성공 0 · 뚫림 없음**.

# 11 침투 탐지 (Suricata)

웹 층 차단과 별개로 , 네트워크 층에서도 같은 공격을 탐지하도록 Suricata 룰을 작성했습니다 .

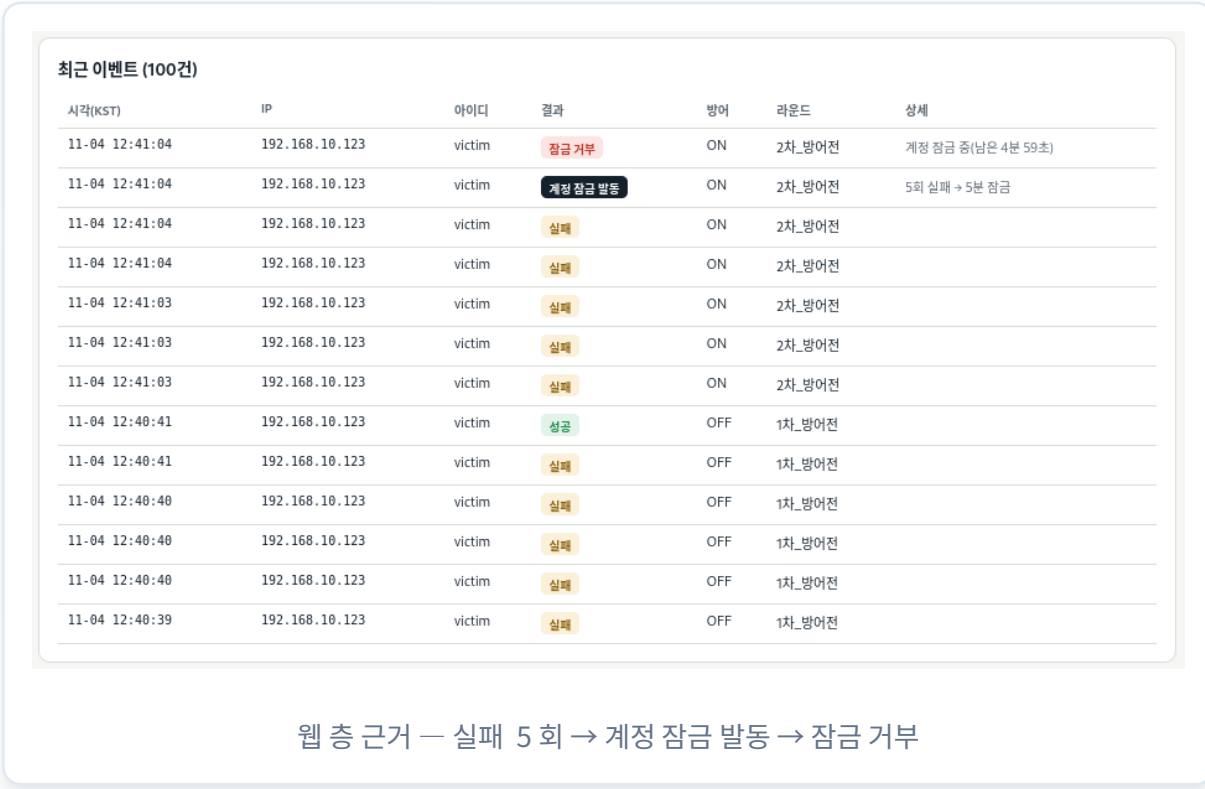
### 탐지 룰 (local.rules)

```
alert http any any -> any 8080 (
 msg:"SecureLogin Brute Force Attempt";
 flow:to_server; content:"POST"; content:"/login";
 threshold: track by_src, count 5, seconds 10;
 sid:1000001;)
```

### 탐지 결과 (fast.log)

```
[1:1000001:1] SecureLogin Brute Force Attempt
[Priority: 3] {TCP}
192.168.10.123:34892 -> 192.168.10.111:8080
```

10 초 안에 /login POST 가 5 회를 넘으면 경보 . 공격 트래픽을 네트워크 단에서 탐지 성공 .



최근 이벤트 (100건)

| 시각(KST) | IP | 아이디 | 결과 | 방어 | 라운드 | 상세 |
|---|---|---|---|---|---|---|
| 11-04 12:41:04 | 192.168.10.123 | victim | 잠금 거부 | ON | 2차_방어전 | 계정 잠금 중(남은 4분 59초) |
| 11-04 12:41:04 | 192.168.10.123 | victim | 계정 잠금 발동 | ON | 2차_방어전 | 5회 실패 → 5분 잠금 |
| 11-04 12:41:04 | 192.168.10.123 | victim | 실패 | ON | 2차_방어전 | |
| 11-04 12:41:04 | 192.168.10.123 | victim | 실패 | ON | 2차_방어전 | |
| 11-04 12:41:03 | 192.168.10.123 | victim | 실패 | ON | 2차_방어전 | |
| 11-04 12:41:03 | 192.168.10.123 | victim | 실패 | ON | 2차_방어전 | |
| 11-04 12:41:03 | 192.168.10.123 | victim | 실패 | ON | 2차_방어전 | |
| 11-04 12:40:41 | 192.168.10.123 | victim | 성공 | OFF | 1차_방어전 | |
| 11-04 12:40:41 | 192.168.10.123 | victim | 실패 | OFF | 1차_방어전 | |
| 11-04 12:40:40 | 192.168.10.123 | victim | 실패 | OFF | 1차_방어전 | |
| 11-04 12:40:40 | 192.168.10.123 | victim | 실패 | OFF | 1차_방어전 | |
| 11-04 12:40:40 | 192.168.10.123 | victim | 실패 | OFF | 1차_방어전 | |
| 11-04 12:40:39 | 192.168.10.123 | victim | 실패 | OFF | 1차_방어전 | |

웹 층 근거 — 실패 5 회 → 계정 잠금 발동 → 잠금 거부

# 12 대응 방안

## 구현한 방어

### 계정 잠금

계정 10 분 5 회 실패 → 5 분 잠금

### IP 차단

IP 10 분 20 회 실패 → 10 분 차단

### 비밀번호 해시

werkzeug 해시 · 아이디 노출 방지

### 이벤트 기록 · 경보

전 시도 로깅 + Suricata 탐지

## 추가 권장 ( 심화 )

- 지수적 지연 ·CAPTCHA — 실패가 쌓일수록 응답 지연 , 자동화 차단으로 공격 속도 저하
- 다중 인증 (MFA) — 비밀번호가 뚫려도 2 차 인증 없이는 로그인 불가
- 비밀번호 정책 — 최소 길이 · 복잡도 , 유출된 비밀번호 (iloveyou 등 ) 차단
- 모니터링 · 알림 — 임계 초과 시 관리자 실시간 알림 , SIEM 연동

# 13 결론 및 성과

- 로그인 실패 제한 부재 (A07) 가 무차별 대입에 그대로 노출됨을 직접 재현
- 계정 잠금 · IP 차단 ( 웹 ) 과 Suricata 탐지 ( 네트워크 , A09) 로 같은 공격을 차단 · 탐지
- 같은 조건의 전 / 후 비교로 성공 1 → 0, 뚫린 계정 victim → 없음 을 수치로 입증
- 웹 차단 + 네트워크 탐지를 묶어 심층 방어 (Defense in Depth) 를 실제로 적용

**향후 과제** GNS3 라우터 기반 망 연동 · 웹 · 네트워크 로그 시각 동기화 · MFA 등 심화 방어 적용